Metodología OSINT orientada a amenazas para el análisis de malware financiero y campañas asociadas: Caso práctico ZeusBank

Propuesta de hoja de ruta basada en el tipo de amenaza, el dato inicial y los niveles de inteligencia estratégico, táctico y operativo

Vamos a desarrollar una metodología general para malware financiero y la ilustraré, con el caso concreto de ZeusBank como ejemplo práctico o caso de estudio.

1. Introducción

El **uso de fuentes abiertas de información, conocido como OSINT (Open Source Intelligence)**, se ha consolidado como un recurso clave para apoyar la identificación, el análisis y la contextualización de amenazas. **Su valor no reside únicamente en la recopilación de datos públicos, sino en la capacidad de transformar dicha información en conocimiento útil para la toma de decisiones en materia de seguridad.**

La aplicación de OSINT al ámbito de las amenazas permite investigar múltiples elementos relacionados con una actividad maliciosa, tales como infraestructuras sospechosas, dominios, direcciones IP, artefactos maliciosos, campañas de phishing, actores o patrones de comportamiento.

La utilidad real de OSINT depende de que su uso esté guiado por un proceso estructurado. Por ello, resulta necesario definir una metodología que permita orientar la búsqueda, seleccionar adecuadamente las fuentes, establecer pivots entre hallazgos y producir inteligencia en función del tipo de amenaza y de los datos iniciales disponibles.

Este trabajo propone una **metodología OSINT orientada a amenazas, centrada específicamente en el análisis de malware financiero y campañas asociadas.**

La metodología planteada parte de una idea fundamental: **la investigación no debe ser igual en todos los casos, sino que debe ajustarse tanto al tipo de amenaza como al dato inicial de partida.** No implica el mismo proceso comenzar una investigación a partir de un dominio sospechoso, una dirección IP, una muestra maliciosa, un hash, una URL o un alias relacionado con una campaña. **Cada uno de estos elementos exige fuentes, herramientas, técnicas de enriquecimiento y rutas de análisis diferentes.**

Además este trabajo incorpora la perspectiva de los **niveles de inteligencia estratégico, táctico y operativo**, con el fin de estructurar los resultados obtenidos de acuerdo con su finalidad.

Finalmente, para ilustrar la aplicabilidad de la propuesta, la metodología se vincula a un caso práctico centrado en ZeusBank, empleado como ejemplo de malware financiero sobre el que validar la lógica del modelo.

Qué es OSINT orientado a amenazas

El término OSINT (Open Source Intelligence) hace referencia al proceso de obtención, recopilación, análisis e interpretación de información procedente de **fuentes abiertas y públicamente accesibles**. Estas fuentes pueden incluir sitios web, redes sociales, foros, blogs, repositorios públicos, registros de dominios, motores de búsqueda, bases de datos especializadas, documentos expuestos en Internet y múltiples servicios accesibles sin recurrir a medios intrusivos o clasificados. Sin embargo, OSINT no debe entenderse como una mera acumulación de datos públicos, sino como un proceso de **transformación de información dispersa en conocimiento útil.**

Cuando este enfoque se aplica al ámbito de la ciberseguridad y de la inteligencia de amenazas, se habla de **OSINT orientado a amenazas**. En este contexto, el objetivo no es solo localizar información disponible en abierto, sino utilizarla de forma sistemática para identificar, contextualizar, relacionar y comprender actividades maliciosas.

El OSINT orientado a amenazas parte de la idea de que una gran parte de los **rastros vinculados a una actividad maliciosa deja huellas observables en Internet.** Estas huellas pueden aparecer en dominios registrados recientemente, direcciones IP expuestas, certificados digitales reutilizados, repositorios con muestras maliciosas, foros donde se comparten herramientas, campañas de phishing visibles en servicios públicos, publicaciones en redes sociales, o menciones a grupos y operaciones delictivas en medios especializados. El valor de la investigación no se encuentra únicamente en localizar estos elementos, sino en **establecer conexiones entre ellos** para convertir hallazgos aislados en inteligencia.

¿Por qué es útil en ciberinteligencia?

El OSINT orientado a amenazas es útil en ciberinteligencia porque **permite recopilar, ampliar y contextualizar información relevante sobre actividades maliciosas a partir de fuentes abiertas y públicamente accesibles**. Su valor principal reside en que facilita la identificación de indicadores, infraestructuras, campañas, actores y patrones de comportamiento sin necesidad de depender exclusivamente de fuentes internas o de acceso restringido.

Además, este enfoque **permite transformar datos dispersos en inteligencia útil para la toma de decisiones**. OSINT orientado a amenazas constituye una herramienta clave para **comprender mejor el entorno de amenazas y apoyar una respuesta más informada y eficaz**.

¿Por qué el malware financiero es un buen escenario de aplicación?

El malware financiero es un buen escenario de aplicación para una metodología OSINT orientada a amenazas porque **suele dejar múltiples rastros observables en fuentes abiertas**. Esto permite investigar la amenaza desde distintos puntos de partida y demostrar cómo cambia la investigación según el dato inicial disponible.

Además, este tipo de malware no se limita únicamente al código malicioso, sino que suele estar vinculado a **campañas de fraude, suplantación de identidad, robo de credenciales e infraestructuras distribuidas**, lo que amplía las posibilidades de análisis y correlación. Gracias a ello, es posible relacionar elementos técnicos con campañas, actores y objetivos concretos.

2. Objetivo y Alcance de la metodología

El objetivo principal del presente trabajo es **diseñar una metodología OSINT orientada a amenazas que permita investigar de forma estructurada malware financiero y las campañas asociadas a este tipo de actividad maliciosa.** La propuesta busca establecer una guía que facilite la recopilación, el enriquecimiento, la correlación y el análisis de información procedente de fuentes abiertas, adaptando el proceso al tipo de amenaza y a los datos iniciales disponibles en cada caso.

La metodología pretende ofrecer un marco de actuación que permite:

- Identificar y clasificar amenazas relacionadas con malware financiero.
- Definir rutas de investigación distintas en función del dato de partida.
- Seleccionar fuentes y herramientas OSINT adecuadas según el contexto.
- Establecer relaciones entre indicadores, infraestructuras, campañas y actores.
- Generar productos de inteligencia útiles en los niveles estratégico, táctico y operativo.

La necesidad de esta metodología radica en que **las investigaciones OSINT no siempre parten del mismo escenario.** En algunos casos, el análisis puede comenzar con una dirección IP, un dominio, una URL o un correo sospechoso, un hash, una muestra de malware, un alias vinculado a fraude o un conjunto de indicadores ya conocidos. **Cada uno de estos elementos de entrada condiciona las fuentes consultadas, los pivots realizados y el tipo de inteligencia que puede obtenerse**.

En cuanto a su **alcance, esta propuesta se centra específicamente en el ámbito del malware financiero**. Dentro de este alcance se contemplan también las campañas asociadas, incluyendo infraestructuras de distribución, dominios maliciosos, correos de phishing, artefactos relacionados, indicadores de compromiso, actores vinculados y patrones operativos observables en fuentes abiertas.

Límites de la metodología

En primer lugar, su eficacia depende de la **disponibilidad, actualidad y fiabilidad de las fuentes abiertas**, ya que no toda la información relevante sobre una amenaza se encuentra accesible públicamente. Además, los resultados obtenidos pueden ser parciales o incompletos, especialmente cuando los actores maliciosos utilizan técnicas de ocultación, infraestructuras efímeras o canales cerrados.

Por otra parte, esta metodología está **orientada al análisis e investigación desde fuentes abiertas**, por lo que no sustituye procedimientos de análisis forense, respuesta ante incidentes o investigación técnica profunda sobre sistemas comprometidos. En consecuencia, debe entenderse como una **herramienta de apoyo a la ciberinteligencia y a la contextualización de amenazas**.

3. Fundamentación teórica

OSINT

OSINT (Open Source Intelligence) es el **proceso de obtención, recopilación y análisis de información procedente de fuentes abiertas y públicas**, como sitios web, redes sociales, foros, registros o repositorios. Su valor no está solo en acceder a la información, sino en **transformar datos dispersos en conocimiento útil.**

En ciberseguridad, OSINT es especialmente relevante porque permite **identificar, ampliar y contextualizar información sobre amenazas, actores, infraestructuras o campañas maliciosas.** Por ello, no debe entenderse como una simple recopilación de datos, sino como una herramienta de apoyo al análisis y a la producción de inteligencia..

Threat intelligence

La threat intelligence o inteligencia de amenazas es el proceso de recopilar, analizar e interpretar información sobre amenazas con el objetivo de convertirla en conocimiento útil para la toma de decisiones en ciberseguridad. Su finalidad no es únicamente identificar indicadores o incidentes, sino comprender el contexto de la amenaza, sus capacidades, motivaciones, técnicas y posibles impactos.

En este sentido, la threat intelligence permite transformar datos técnicos y observaciones aisladas en información estructurada y accionable, útil para anticipar riesgos, priorizar respuestas y apoyar la detección, el análisis y la protección frente a actividades maliciosas.

Diferencia entre inteligencia estratégica, táctica y operativa

La inteligencia estratégica ofrece una visión general de las amenazas, su evolución e impacto; la inteligencia táctica se centra en cómo actúa la amenaza, identificando técnicas y patrones de comportamiento; y la inteligencia operativa se orienta a elementos concretos y accionables, como IOCs o artefactos técnicos, útiles para tareas inmediatas de detección e investigación

Relación entre malware financiero, campañas asociadas e investigación OSINT

El malware financiero forma parte de un ecosistema de amenaza más amplio que incluye infraestructura técnica, campañas de distribución, mecanismos de fraude y, en algunos casos, actores organizados. Su objetivo suele estar relacionado con el **robo de credenciales, la captura de información bancaria, la suplantación de identidad o el beneficio económico ilícito.**

Por ello, su análisis no debe centrarse solo en la muestra maliciosa, sino también en las **campañas asociadas** y en los recursos que permiten su distribución y funcionamiento, como dominios, direcciones IP, correos de phishing o páginas fraudulentas. En este contexto, la **investigación OSINT** resulta esencial, ya que permite identificar, enriquecer y relacionar estos elementos desde fuentes abiertas, facilitando una visión más completa de la amenaza y apoyando la obtención de inteligencia estratégica, táctica y operativa.

4. Variables de entrada de la investigación

IP

La dirección IP puede ser una variable de entrada útil en una investigación OSINT orientada a amenazas, ya que permite identificar infraestructuras relacionadas con una actividad maliciosa, como servidores, sistemas comprometidos o recursos empleados en campañas.

Su análisis puede incluir aspectos como **geolocalización, proveedor, ASN, reputación, historial, puertos y servicios expuestos**. Además, desde una IP es posible realizar pivots hacia dominios relacionados, certificados, resoluciones históricas, otros indicadores o muestras de malware, lo que facilita reconstruir parte de la infraestructura y contextualizar mejor la amenaza.

Dominio

La investigación de dominios es útil porque estos pueden estar vinculados a infraestructuras maliciosas, campañas de phishing, páginas fraudulentas o recursos asociados al malware financiero. Su análisis permite iniciar la investigación desde un elemento observable y ampliar el conocimiento sobre la amenaza y su contexto.

Entre los aspectos más relevantes a revisar están la **fecha de registro, registrador, resolución DNS, IPs asociadas, subdominios, certificados digitales y finalidad aparente del sitio web**. Además, un dominio permite realizar pivots hacia IPs vinculadas, resoluciones históricas, certificados compartidos, otros dominios relacionados, URLs observadas y servicios de reputación.

URL

La URL es una variable de entrada que puede apuntar de forma directa a recursos maliciosos como páginas de phishing, descargas de malware, paneles de acceso, redirecciones o infraestructuras asociadas a una campaña. En el caso del malware financiero, su análisis permite identificar tanto el contenido visible como los elementos técnicos que la rodean. La URL actúa como un punto de entrada útil para relacionar un recurso concreto con la infraestructura y la actividad maliciosa a la que pertenece, facilitando la obtención de inteligencia operativa y táctica.

Correo

El correo electrónico es una variable de entrada muy relevante en el análisis de campañas de phishing, fraude y distribución de malware financiero. Puede actuar como punto de partida para identificar intentos de suplantación, relaciones con dominios sospechosos, infraestructura asociada o posibles patrones de envío vinculados a una campaña maliciosa.

Resulta útil analizar elementos como la dirección del remitente, el dominio asociado, el asunto, posibles enlaces o adjuntos, así como la coherencia entre la identidad mostrada y la real. A partir de esta información, pueden realizarse **pivots** hacia **dominios, URLs, direcciones IP, artefactos maliciosos o campañas relacionadas.**

Hash

El hash es una variable de entrada que permite identificar de forma unívoca una muestra de malware o un archivo sospechoso. En el ámbito del malware financiero, partir de un hash facilita la búsqueda de información sobre la muestra, sus relaciones con otros artefactos, su posible clasificación y su vínculo con campañas o infraestructuras maliciosas.

Es muy importante comprobar su presencia en repositorios de malware, entornos de análisis y servicios de correlación. A partir de ahí, pueden obtenerse nuevos indicadores, como dominios, direcciones IP, URLs, nombres de archivo o familias de malware relacionadas.

Alias

El alias constituye una variable de entrada que puede estar vinculado a actores, perfiles, identidades operativas o campañas maliciosas. En el ámbito del malware financiero, un alias puede aparecer asociado a foros, canales de comunicación, publicaciones, filtraciones o actividades relacionadas con fraude y distribución de malware.

Muestra

La muestra constituye una variable de entrada que permite analizar de forma directa un artefacto potencialmente malicioso y obtener información sobre su comportamiento, relaciones y contexto. En el caso del malware financiero, una muestra puede servir como punto de partida para identificar indicadores, infraestructura asociada, capacidades del malware y posibles vínculos con campañas concretas.

Es necesario extraer metadatos, nombres de archivo, hashes, cadenas relevantes, comportamiento observado y relaciones con otros artefactos. A partir de esta información, pueden realizarse **pivots hacia dominios, direcciones IP, URLs, familias de malware o campañas relacionadas.**

IOC

Los IOCs - Indicators of Compromise, constituyen una variable de entrada que representan evidencias técnicas asociadas a una posible actividad maliciosa. En el ámbito del malware financiero, los IOCs pueden incluir direcciones IP, dominios, URLs, hashes, correos electrónicos o nombres de archivo relacionados con campañas, infraestructuras o artefactos concretos.

Los IOCs pueder ser utilizados como base para nuevos pivots hacia otros indicadores o elementos asociados. Este proceso permite ampliar la visibilidad sobre la amenaza y relacionar distintos observables dentro de una misma campaña o infraestructura.

5. Fases de la metodología

5.1 Identificación y clasificación inicial

La fase de identificación y clasificación inicial es el punto de partida de la metodología, ya que permite delimitar el alcance de la investigación y establecer una base para el resto del proceso. Su objetivo es definir **qué se investiga, qué tipo de amenaza se sospecha y con qué información inicial se cuenta**.

Para ello, primero se realiza una **definición del problema**, describiendo brevemente el contexto, el riesgo y la finalidad del análisis. Después, se lleva a cabo la **identificación del tipo de amenaza**, lo que ayuda a orientar el enfoque y seleccionar mejor las fuentes y herramientas. Por último, se determina el **dato inicial**, es decir, el primer elemento observable desde el que comenzará la investigación y a partir del cual se establecerán los primeros pivots.

5.2 Recolección OSINT

La fase de recolección OSINT tiene como objetivo obtener información relevante a partir de fuentes abiertas y públicamente accesibles que permita ampliar el conocimiento sobre la amenaza investigada. Una vez identificado el problema, clasificado el tipo de amenaza y determinado el dato inicial, esta etapa se orienta a localizar información útil que sirva como base para el análisis posterior. En el contexto del malware financiero, esta recolección puede centrarse en infraestructuras sospechosas, dominios, direcciones IP, correos, muestras, hashes, alias o indicadores relacionados con campañas maliciosas.

A partir de esta búsqueda, se procede a la **obtención de artefactos relacionados**, es decir, a la recopilación de elementos observables que puedan estar vinculados a la amenaza.

5.3 Enriquecimiento y pivots

La fase de enriquecimiento y pivots tiene como finalidad ampliar la información obtenida durante la recolección inicial y profundizar en el análisis de la amenaza a partir de los datos ya identificados. En esta etapa, la investigación deja de centrarse únicamente en el dato de partida y comienza a explorar sus relaciones con otros elementos observables, permitiendo construir una visión más completa del caso analizado.

En el caso del malware financiero, este enfoque permite relacionar artefactos técnicos con dominios, direcciones IP, recursos de distribución, campañas de phishing, posibles actores implicados y patrones de actuación observados en fuentes abiertas.

5.4 Correlación y análisis

La fase de correlación y análisis tiene como objetivo transformar la información recopilada y enriquecida en conocimiento estructurado sobre la amenaza investigada. En este punto, la metodología deja de centrarse únicamente en la obtención de datos y se orienta a interpretar su significado, valorar su relación con otros hallazgos y determinar su utilidad dentro del proceso de ciberinteligencia.

Finalmente, los resultados obtenidos se someten a una clasificación según el nivel de inteligencia al que contribuyen.

5.5 Producción de inteligencia

En esta fase, la información obtenida se convierte en resultados estructurados y útiles para la toma de decisiones. Entre ellos se incluye un informe que resume la investigación, el contexto, los hallazgos y la interpretación final de la amenaza.

Además, se recopilan los IOCs, que pueden utilizarse en tareas de detección, monitorización y seguimiento. También puede elaborarse un mapa relacional para representar las conexiones entre infraestructura, artefactos, actores, campañas e indicadores, facilitando una visión más completa de la amenaza.

Junto a ello, se genera un perfil de campaña, que permite contextualizar la amenaza a partir de sus objetivos, medios de distribución, infraestructura y patrones observados. Finalmente, esta fase se cierra con unas conclusiones que sintetizan los hallazgos principales y valoran la utilidad de la metodología aplicada.

6. Fuentes y herramientas

6.1 Investigación de infraestructura

La investigación de infraestructura permite identificar y contextualizar los recursos técnicos utilizados en una actividad maliciosa. En el caso del malware financiero, resulta útil para analizar dominios, direcciones IP, subdominios, DNS, certificados y servicios expuestos que puedan formar parte de una campaña.

Para ello, se emplean fuentes y herramientas orientadas al registro, resolución, reputación y relación entre activos, como **WHOIS/RDAP, DNS y passive DNS, y plataformas como Shodan o Censys**, que ayudan a ampliar la visibilidad sobre la infraestructura asociada a la amenaza.

6.2 Investigación de artefactos maliciosos

La investigación de artefactos maliciosos se centra en el análisis de **muestras, hashes, nombres de archivo y otros elementos técnicos vinculados al malware.** En el caso del malware financiero, permite identificar características de la amenaza, relacionarla con otras muestras y ampliar la visibilidad sobre campañas e infraestructuras asociadas.

Para ello, se utilizan fuentes y herramientas orientadas a la **consulta, clasificación y correlación de artefactos**, como servicios de análisis de muestras, repositorios de hashes, sandboxes públicas y plataformas de inteligencia de malware. Además, este tipo de investigación permite realizar pivots técnicos desde una muestra o hash hacia nuevos indicadores, recursos de red, archivos relacionados o campañas previas, facilitando una comprensión más amplia de la amenaza.

6.3 Investigación de identidad y presencia digital

La investigación de identidad y presencia digital se centra en el **análisis de alias, correos, nombres de usuario, perfiles y otras huellas públicas relacionadas con actores o campañas maliciosas.** En el caso del malware financiero, permite contextualizar identidades operativas, detectar reutilización de nombres o correos y relacionar la amenaza con comunidades o entornos digitales relevantes.

Para ello, se recurre a la **búsqueda en plataformas abiertas, redes sociales, foros, repositorios, motores de búsqueda y servicios de correlación.** Además, este tipo de investigación permite **realizar pivots no estrictamente técnicos**, aportando contexto adicional y enriqueciendo la comprensión global de la amenaza.

6.4 Contextualización y threat intelligence

La contextualización y threat intelligence **permite situar los hallazgos dentro de un marco analítico más amplio**, ayudando a comprender no solo qué elementos técnicos se han identificado, sino también qué significado tienen dentro de una amenaza o campaña concreta. En el caso del malware financiero, esta fase sirve para relacionar indicadores, artefactos, infraestructura y posibles actores con patrones de comportamiento y campañas previas.

Para ello, se **emplean plataformas de inteligencia, repositorios de indicadores, informes especializados y marcos de referencia** que aportan contexto adicional. Además, esta fase permite clasificar la información según su utilidad **estratégica, táctica u operativa**, facilitando una interpretación más completa de la amenaza.

7. Niveles de inteligencia aplicados a la metodología

7.1 Nivel estratégico

El nivel estratégico aplicado a la metodología se orienta a obtener una visión general de la amenaza y de su impacto dentro de un contexto más amplio. En el caso del malware financiero, este nivel permite analizar tendencias, evolución de campañas, sectores más afectados, objetivos habituales y relevancia del riesgo para organizaciones o entornos concretos.

A diferencia de los niveles más técnicos, la inteligencia estratégica no se centra en indicadores específicos, sino en la comprensión global de la amenaza, su importancia y sus posibles implicaciones. Por ello, su utilidad principal reside en apoyar la planificación, la priorización de riesgos y la toma de decisiones a un nivel más organizativo o directivo.

7.2 Nivel táctico

El nivel táctico se centra en comprender cómo actúa la amenaza, identificando las técnicas, procedimientos, patrones de comportamiento e infraestructuras utilizadas en una campaña. En el caso del malware financiero, este nivel permite analizar métodos de distribución, mecanismos de infección, recursos técnicos empleados y posibles relaciones entre distintos artefactos o indicadores.

Su utilidad principal reside en ofrecer una visión más detallada del modo de operación de la amenaza, facilitando la contextualización de campañas y la comprensión de su funcionamiento. De este modo, la inteligencia táctica actúa como un punto intermedio entre la visión global del nivel estratégico y el detalle concreto del nivel operativo.

7.3 Nivel operativo

El nivel operativo se orienta a la identificación y uso de elementos concretos y accionables relacionados con la amenaza, como direcciones IP, dominios, URLs, hashes, correos electrónicos, muestras o cualquier otro indicador de compromiso. En el caso del malware financiero, este nivel permite trabajar directamente con los artefactos técnicos observados durante la investigación.

Su principal utilidad reside en apoyar tareas inmediatas de detección, seguimiento, enriquecimiento e investigación técnica, proporcionando información aplicable a corto plazo. De este modo, la inteligencia operativa representa el nivel más práctico y específico dentro de la metodología, al centrarse en observables directamente relacionados con una campaña o actividad maliciosa.

8. Diagrama metodológico



donde:

- El flujo metodológico comienza con la identificación y clasificación inicial, donde se define el problema, el tipo de amenaza y el dato de partida. A partir de ahí, la investigación se adapta a la variable de entrada disponible, que condiciona las fuentes y la ruta de análisis.
- Después se realiza la recolección OSINT, orientada a localizar información relevante y obtener artefactos relacionados. Esta información se amplía en la fase de enriquecimiento y pivots, mediante nuevas relaciones entre indicadores, infraestructura, muestras, actores y campañas.
- Finalmente, los hallazgos se someten a correlación y análisis, identificando patrones y clasificando los resultados según su utilidad estratégica, táctica u operativa. El proceso concluye con la producción de inteligencia, reflejada en informes, IOCs, mapas relacionales, perfiles de campaña y conclusiones.

9. Caso de aplicación: ZeusBank

Veamos cómo se aplicaría la metodología, en el caso del malware ZeusBank. Como caso de aplicación de la metodología propuesta se toma ZeusBank, un ejemplo de malware financiero orientado al robo de credenciales e información sensible relacionada con servicios bancarios y entornos de autenticación. Este tipo de amenaza resulta adecuado para validar la metodología, ya que combina elementos técnicos, infraestructura asociada y posibles campañas de distribución, lo que permite aplicar de forma práctica una investigación OSINT orientada a amenazas.

El interés del caso reside en que ZeusBank puede analizarse no sólo como una muestra o artefacto malicioso aislado, sino como parte de un ecosistema más amplio en el que intervienen dominios, direcciones IP, URLs, correos de phishing, indicadores de compromiso y posibles recursos vinculados a una campaña. Esto permite demostrar cómo la metodología puede adaptarse al dato inicial disponible y generar inteligencia útil a distintos niveles.

9.1 Identificación y clasificación inicial

- Definición del problema: En este caso de aplicación, el problema de investigación consiste en analizar una muestra identificada como Zeus Banking Trojan con el fin de determinar su naturaleza, los artefactos asociados, la infraestructura relacionada y los indicadores útiles para una investigación OSINT orientada a amenazas. El writeup tomado como referencia trabaja con una muestra de 2013 obtenida del repositorio theZoo, nombrada `invoice_2318362983713_823931342io.pdf.exe`, con `MD5 ea039a854d20d7734c5add48f1a51c34` y `SHA-256 69e966e730557fde8fd84317cdef1ece00a8bb3470c0b58f3231e170168af169`.

- Identificación del tipo de amenaza: ZeusBank se clasifica dentro de la categoría de malware financiero o troyano bancario, ya que el análisis lo describe como una variante de Zeus/Zbot orientada al robo de credenciales bancarias, con capacidades de form-grabbing, keylogging, comunicación con servidor de mando y control, entrega de otros módulos y persistencia mediante modificaciones en el registro de Windows.

- Determinación del dato inicial: Para este caso, los datos iniciales más sólidos son la muestra y su hash, ya que son los observables mejor documentados en el análisis y permiten activar pivots hacia otros elementos técnicos. A partir de ellos podemos ampliar el caso hacia nombre de fichero, comportamiento, dominio observado, URL de red, procesos hijos, DLL relacionada e indicadores de persistencia.

9.2 Selección de variable de entrada

La metodología permite iniciar la investigación desde distintas variables. En el caso ZeusBank, la aplicabilidad de cada una sería la siguiente:

- IP: El writeup no publica una IP concreta como IOC principal, por lo que esta no sería la entrada más fuerte del caso. Aun así, metodológicamente una IP podría utilizarse si se obtuviera durante el análisis de red o por correlación posterior con dominios y servicios asociados.

- Dominio: Sí existe una entrada útil por dominio, ya que el análisis estático menciona la presencia de `corect[.]com` dentro de la muestra y muestra que fue revisado posteriormente en VirusTotal y Wayback Machine. Esto convierte al dominio en una variable válida para iniciar pivots hacia historial, contenido, reputación y posible relación con la campaña.

- URL: También existe una entrada clara por URL, ya que durante el análisis dinámico se observó una petición `HTTP GET /get/flashplayer/update/current/install/install_all_win_cab_64_ax_sgn.z` dirigida al host `fpdownload.macromedia.com`. En la metodología, esta URL serviría para pivotar hacia dominio, comportamiento de descarga y artefactos asociados al intento de instalación o entrega de componentes.

- Correo electrónico: El artículo no aporta un correo concreto como evidencia, pero el nombre del fichero `invoice_...pdf.exe` sugiere un señuelo de tipo factura falsa, coherente con campañas de ingeniería social. Por ello, en una aplicación ampliada de la metodología, el correo electrónico podría ser una variable de entrada razonable si se dispusiera del mensaje original.

- Hash: El hash es una de las mejores variables de entrada para ZeusBank, ya que permite identificar de forma precisa la muestra y contrastarla en repositorios y plataformas de inteligencia. El writeup aporta tanto el MD5 como el SHA-256 y señala que la muestra aparecía identificada como Zeus/Zbot por múltiples motores.

- Alias: Como alias o denominación operativa, el caso sí presenta referencias a Zeus, Zbot y Zeus Banking Trojan, útiles para búsquedas OSINT sobre familia, variantes, writeups previos y campañas relacionadas. Sin embargo, el artículo no atribuye la muestra a un actor humano concreto ni a un alias de operador.

- Muestra: La muestra es, junto al hash, la variable de entrada principal del caso. El análisis confirma que se trata de un ejecutable PE de 32 bits para Windows y que su nombre está diseñado para aparentar un PDF de factura, lo que la convierte en un punto de partida adecuado para investigación técnica y contextual.

- IOCs: El caso también puede arrancar desde IOCs ya conocidos. Entre los observables concretos del writeup destacan el nombre del archivo, sus hashes, el dominio corect[.]com, la URL observada en tráfico HTTP, el fichero InstallFlashPlayer.exe y la DLL msimg32.dll, que fue identificada como maliciosa por numerosos motores.

- Infraestructura peligrosa: Como entrada por infraestructura peligrosa, el caso permite trabajar con la ruta temporal `C:\Users\TraceX0\AppData\Local\Temp\`, donde se observó actividad relevante, junto con procesos lanzados desde allí y modificaciones de registro para persistencia. Esto permite considerar la infraestructura local y los mecanismos de persistencia como parte del ecosistema técnico de la amenaza.

9.3 Recolección OSINT

- Búsqueda inicial en fuentes abiertas: La recolección OSINT del caso ZeusBank puede iniciarse a partir del hash o del nombre de la muestra en fuentes abiertas y repositorios públicos. En el writeup, la muestra procede de theZoo y posteriormente se contrasta en VirusTotal, donde aparece identificada por múltiples motores como Zeus/Zbot. Además, el dominio encontrado en la muestra fue revisado en Wayback Machine y en servicios de reputación, lo que muestra una ruta de recolección válida basada en fuentes abiertas.

- Obtención de artefactos relacionados: Como resultado de esa recolección inicial, se obtienen artefactos técnicos y contextuales relevantes: hashes, nombre de archivo, familia asociada, dominio incrustado, URL observada en tráfico, procesos hijos, DLL relacionada y claves de persistencia potencialmente afectadas. Estos artefactos permiten pasar de una muestra aislada a un conjunto de observables reutilizables para inteligencia y correlación.

9.4 Enriquecimiento y pivots

- Ampliación a partir del dato inicial: Partiendo del hash o de la muestra, la investigación puede ampliarse hacia otros elementos observados en el análisis. El writeup muestra cómo desde la muestra se pasa al nombre de archivo engañoso, a cadenas sospechosas, a APIs relevantes, al dominio incrustado y, más tarde, al tráfico de red y a los ficheros generados durante la ejecución.

- Relación con infraestructura: En términos de infraestructura, el caso permite relacionar la muestra con el dominio corect[.]com, con la petición al host fpdownload.macromedia.com y con la actividad en el directorio temporal del sistema. Además, el análisis de red y de sistema permite considerar la persistencia en registro y los procesos lanzados como parte del soporte operativo de la amenaza.

- Relación con muestras: El caso también permite enriquecer por relación con otras muestras y artefactos. El writeup destaca que la DLL msimg32.dll fue detectada como maliciosa por numerosos motores y la vincula a inyección o ejecución maliciosa durante el comportamiento de la muestra. De igual modo, la clasificación reiterada como Zeus/Zbot facilita la relación con otras muestras de la misma familia.

- Relación con actores: La relación con actores, en este caso, no se orienta a una atribución personal concreta, sino a la asociación con la familia Zeus/Zbot y con el ecosistema histórico de troyanos bancarios. El valor del pivot aquí está más en el contexto de amenaza y en la familia malware que en la identificación de un operador nominal.

- Relación con campañas asociadas: El nombre de fichero tipo factura, el intento de descargar o simular una instalación de Flash Player, la persistencia en registro y la capacidad de robo de credenciales permiten relacionar ZeusBank con campañas basadas en ingeniería social, distribución engañosa y monetización mediante fraude bancario. Estos elementos son coherentes con una campaña de malware financiero y no con un simple artefacto aislado.

9.5 Correlación y análisis

- Conexión entre hallazgos: La correlación del caso ZeusBank conecta varios niveles de evidencia: un ejecutable PE de 32 bits disfrazado de factura, una identificación consistente como Zeus/Zbot, la presencia de un dominio embebido, actividad de descarga relacionada con Flash Player, procesos hijos como InstallFlashPlayer.exe, cmd.exe y conhost.exe, persistencia mediante registro y una DLL maliciosa asociada. En conjunto, estos elementos refuerzan la interpretación del caso como malware financiero con comportamiento evasivo y persistente.

- Identificación de patrones: Entre los patrones observables destacan el uso de ingeniería social mediante nombre de archivo engañoso, la utilización de instaladores o señuelos de software legítimo, la autoeliminación del binario original, el spawn de procesos hijos, la modificación del registro para persistencia y la presencia de capacidades de evasión de análisis y detección de entorno virtual. Estos patrones son especialmente útiles para caracterizar la amenaza a nivel táctico.

- Clasificación por nivel de inteligencia: La clasificación del caso permite distribuir los hallazgos en distintos niveles. Los hashes, nombres de archivo, URLs, dominios, procesos y DLLs corresponden al nivel operativo; los patrones de evasión, persistencia y entrega se sitúan en el nivel táctico; y la relación del caso con el ecosistema de troyanos bancarios y con campañas de fraude financiero se ubica en el nivel estratégico.

9.6 Niveles de inteligencia

- Estratégico: A nivel estratégico, ZeusBank permite ilustrar cómo un troyano bancario combina robo de credenciales, persistencia y entrega de componentes adicionales dentro de un modelo de amenaza centrado en el beneficio económico. El caso es útil para contextualizar el malware financiero como una amenaza sostenida y adaptable.

- Táctico: A nivel táctico, el caso muestra técnicas observables como engaño por nombre de archivo, persistencia en registro, detección de entornos virtuales, uso de procesos hijos y posible inyección mediante DLL. También aporta un dominio y una URL concretos que pueden conectarse con el comportamiento de la muestra.

- Operativo: A nivel operativo, el caso proporciona observables accionables: MD5, SHA-256, nombre de archivo, corect[.]com, la petición HTTP hacia fpdownload.macromedia.com, el archivo InstallFlashPlayer.exe, la DLL msimg32.dll y referencias a rutas y claves de persistencia.

9.7 Producción de inteligencia

- Informe: El producto principal sería un informe de inteligencia que resuma el caso, describa la amenaza como malware financiero, exponga los hallazgos principales y explique las relaciones entre muestra, infraestructura, comportamiento y campaña.

- IOCs: Los IOCs más relevantes del caso serían, como mínimo, los hashes de la muestra, el nombre del archivo, el dominio corect[.]com, la URL observada en el tráfico, la DLL msimg32.dll y los procesos relacionados con la ejecución.

- Mapa relacional: El mapa relacional debería conectar la muestra invoice_2318362983713_823931342io.pdf.exe con sus hashes, la familia Zeus/Zbot, el dominio observado, la petición de red asociada, los procesos hijos y la DLL detectada como maliciosa.

- Perfil de campaña: El perfil de campaña describiría una amenaza de malware financiero distribuida mediante engaño, con apariencia de documento legítimo, uso de señuelos tipo actualización de Flash Player, mecanismos de persistencia, evasión de análisis y capacidad de robo de credenciales.

- Conclusiones: Como conclusión, el caso ZeusBank demuestra que la metodología propuesta funciona bien cuando se parte de una muestra o de un hash y se expande mediante pivots hacia infraestructura, comportamiento, artefactos secundarios e indicadores. También muestra que, incluso en un caso histórico, OSINT permite reconstruir contexto, extraer inteligencia útil y organizar el análisis en niveles estratégico, táctico y operativo.

10. Conclusión

La metodología propuesta aporta una **guía estructurada para realizar investigaciones OSINT orientadas a amenazas**, aplicada en este trabajo al análisis de malware financiero y campañas asociadas. Su principal valor es que organiza la investigación en fases claras, desde la identificación del problema hasta la producción de inteligencia útil.

Además, se trata de una metodología **reutilizable**, ya que puede adaptarse a otros casos y amenazas manteniendo la misma lógica de trabajo. Su enfoque basado en el **dato inicial** y en el **tipo de amenaza** permite seleccionar mejor las fuentes, herramientas y pivots, haciendo la investigación más coherente, ordenada y eficaz.

Entre sus ventajas, destaca la posibilidad de transformar datos aislados en **inteligencia operativa, táctica y estratégica**, facilitando una comprensión más amplia de la amenaza y de su contexto.

No obstante, la metodología también presenta **limitaciones**. Su eficacia depende de la disponibilidad, calidad y actualidad de las fuentes abiertas, y no sustituye análisis forenses ni investigaciones técnicas profundas sobre sistemas comprometidos. Por ello, debe entenderse como una herramienta de apoyo a la ciberinteligencia y no como una solución completa por sí sola.